HUNT-SAGE · THREAT HUNTING CHEAT SHEET

Active Directory Attacks to Artefacts

A map from AD and Entra attack technique to the exact events it leaves, the hunt signal, and the auditing you must turn on to see it.

github.com/iamjammie/hunt-sage · iamjammie.github.io/hunt-sage · Built 2026-11-03

Most AD attacks abuse legitimate protocols (Kerberos, LDAP, DRSUAPI, certificate enrolment), so the artefact is rarely an alert: it is a normal event in an abnormal pattern. Think in **tiers**: anything that touches Tier 0 (domain controllers, the `krbtgt` account, Enterprise/Domain/Schema Admins, AD CS certificate authorities, ADFS/Entra Connect, backup infrastructure) is the crown jewels. A workstation account suddenly reading replication secrets, or a normal user enrolling for a certificate as an admin, is the hunt.

Event IDs below are Windows Security log unless noted. Many require auditing that is **off by default**: see "Turn the auditing on". Field names follow the event schema; adapt to your SIEM parser.

Credential access and Kerberos abuse

Attack	How it works	Telemetry	Hunt signal	ATT&CK
Password spray	One or few passwords against many accounts	4625, 4771 (Kerberos pre-auth fail, status `0x18`), 4776 (NTLM), Entra sign-ins	Many distinct users, one source, few tries each, inside a short window	T1110.003
Kerberoasting	Request service tickets (TGS) for SPNs, crack offline	4769 with `TicketEncryptionType 0x17` (RC4) and `TicketOptions`	One account requesting many distinct SPNs; RC4 where the realm is AES	T1558.003
AS-REP roasting	Request AS-REP for accounts with pre-auth disabled	4768 with `PreAuthType 0`, RC4	Requests for the small set of no-preauth accounts; bursts	T1558.004
Timeroasting	Abuse MS-SNTP to get computer-account hashes without auth	NTP traffic to DCs; no native event	Unauthenticated SNTP requests enumerating RIDs; network telemetry	T1558
DCSync	Replicate secrets via DRSUAPI `DRSGetNCChanges`	4662 with replication property GUIDs (`1131f6aa/ab/ad-...`); Zeek `dce_rpc` `drsuapi`	Replication requested by a non-DC account or from a non-DC host	T1003.006
NTDS.dit theft	Copy the AD database via VSS/ntdsutil/esentutl	Sysmon 1 (`ntdsutil ... ifm`, `vssadmin create shadow`), Sysmon 9 (RawAccessRead), 4688; file creation of `ntds.dit`	A copy of `ntds.dit` plus the SYSTEM hive outside a backup window	T1003.003
LSASS dumping on a DC	Read DC process memory	Sysmon 10 on `lsass.exe` from a non-system process; 4656/4663 with LSASS access masks	Credential-dump access masks (`0x1010`, `0x1438`, `0x143A`) against LSASS	T1003.001
DPAPI domain backup key	Steal the domain DPAPI master key to decrypt any user secret	4662 read of the `BCKUPKEY` secret object; LSADump-style access	Reads of the domain backup key object by non-Tier-0 identities	T1555
LAPS password read	Read local-admin passwords from AD	4662 / 4663 read of `ms-Mcs-AdmPwd` or `msLAPS-Password` / `msLAPS-EncryptedPassword`	One account reading LAPS attributes across many computers	T1555

Lateral movement and ticket abuse

Attack	How it works	Telemetry	Hunt signal	ATT&CK
Pass-the-hash	Use an NTLM hash directly	4624 type 3 NTLM, `KeyLength 0`; sometimes type 9 (`seclogon`)	An admin authenticating from a new source with no preceding interactive logon	T1550.002
Pass-the-ticket / overpass-the-hash	Reuse stolen tickets or request tickets from a key	4768/4769 RC4 for an AES-capable principal; 4769 with no matching 4768 from the same host	TGS without a preceding TGT; abnormal ticket lifetimes	T1550.003

Attack	How it works	Telemetry	Hunt signal	ATT&CK
Golden ticket	Forge a TGT with the `krbtgt` key	4769/4624 for accounts that never produced a 4768; lifetimes over policy; SID-history oddities	Service tickets for principals that never authenticated; RC4 where AES is expected	T1558.001
Silver ticket	Forge a TGS with a service account key	A service logon (4624) with no corresponding 4769 on any DC	Service access with the DC-side ticket event missing	T1558.002
Diamond / Sapphire ticket	Modify a real TGT rather than forge one	Subtle: ticket group/claim mismatches, PAC anomalies (needs PAC validation)	Privileged group membership in a ticket that LDAP does not reflect	T1558
NTLM relay (LLMNR/NBT-NS/mDNS/WPAD poisoning)	Capture then relay auth to SMB/LDAP/AD CS	4624 type 3 where source IP does not match the host name; LDAP signing events 2889; Zeek `ntlm.log`	Machine accounts authenticating from non-owner IPs; auth to LDAP/HTTP from a relay host	T1557.001
Kerberos relay	Relay coerced Kerberos auth (krbrelayx, DNS spoof)	4768/4769 with service names pointing at attacker-controlled hosts	Unexpected SPNs resolved via a poisoned DNS record	T1557
Authentication coercion (PetitPotam, PrinterBug, ShadowCoerce, DFSCoerce)	Force a machine (often a DC) to authenticate to you	MS-EFSRPC/MS-RPRN/MS-FSRVP/MS-DFSNM RPC calls; Zeek `dce_rpc`	A DC machine account authenticating outbound to a non-DC host	T1187

Privilege escalation via AD CS

Active Directory Certificate Services turns a certificate into a logon. The ESC1 to ESC16 family abuses template permissions, CA flags, enrolment-agent rights, weak certificate mappings and NTLM/Kerberos relay to web/RPC enrolment. One issued certificate for a privileged principal is persistent until it expires.

Vector	Telemetry	Hunt signal	ATT&CK
Template/EKU abuse (ESC1-3, ESC9/10/13-16)	CA events 4886 (request) and 4887 (issued); template change events 4898/4899/4900	A request where the Subject Alternative Name names a different, privileged user; client-auth cert issued to a non-privileged enrollee	T1649
CA config / flag abuse (ESC6, ESC7)	4890 (CA config changed), 4882 (security permissions changed on CA)	`EDITF_ATTRIBUTESUBJECTALTNAME2` set; ManageCA/ManageCertificates granted to non-admins	T1649
Relay to enrolment (ESC8 web, ESC11 ICPR RPC)	4886/4887 from the CA; coercion artefacts above; machine account enrolling	A certificate issued after a relayed machine-account authentication	T1649, T1557
Certifried (CVE-2022-26923)	4741/4742 machine account create/edit of `dNSHostName`; 4886/4887	A new or edited machine account whose `dNSHostName` collides with a DC, then a cert request	T1649
PKINIT logon with a forged/abused cert	4768 containing certificate information; 4624 follow-on	A certificate logon for an admin from a host that never held that identity	T1649

See the AD CS abuse playbook. Baseline your templates with Certify/Certipy-style audits before hunting, so you know which SAN-supplied requests are expected.

DACL, delegation and object abuse

Attack	Telemetry	Hunt signal	ATT&CK
ACL abuse (GenericAll, WriteDACL, WriteOwner, GenericWrite)	4662, 5136 (directory object modified), 4670 (permissions changed)	New rights granted on privileged objects, AdminSDHolder, the domain head or group objects	T1222.001, T1098
Shadow credentials	5136 writing `msDS-KeyCredentialLink`, then PKINIT (4768 with cert info)	Key-credential writes by accounts that are not the device or an MDM/sync service	T1556
Resource-based constrained delegation (RBCD)	5136 writing `msDS-AllowedToActOnBehalfOfOtherIdentity`; 4769 S4U2Proxy	A computer object's RBCD attribute set by a non-admin, then protocol-transition tickets	T1098

Attack	Telemetry	Hunt signal	ATT&CK
Unconstrained / constrained delegation abuse	4738 (`TrustedForDelegation` / `msDS-AllowedToDelegateTo` change); 4769/4624	Delegation flags enabled on a non-Tier-0 host; that host then receiving admin tickets	T1558
GPO abuse	5136 on `groupPolicyContainer` ; SYSVOL file changes (object access on `\\domain\SYSVOL`)	GPO edits by non-GPO admins; a new immediate scheduled task or startup script in SYSVOL	T1484.001
dMSA abuse (BadSuccessor)	5136 writing `msDS-ManagedAccountPrecededByLink` / `msDS-DelegatedMSAState` on a dMSA	A delegated MSA created or linked to inherit a privileged account's context	T1098, T1078
Machine account quota / sAMAccountName spoofing (noPac)	4741 (create), 4742 (edit), 4781 (rename)	A standard user creating a machine account then renaming it to collide with a DC	T1136.002

Persistence and domain dominance

Attack	Telemetry	Hunt signal	ATT&CK
AdminSDHolder abuse	5136 on the `AdminSDHolder` container	ACL additions that SDProp then propagates to all protected groups	T1098
SID history injection	4765/4766 (SID history add / add failed); DCShadow or DB edit	A standard account carrying a privileged SID in `sIDHistory`	T1134.005
Skeleton key	Sysmon 10 on `lsass.exe` from a non-system process on a DC; new driver (`mimidrv`)	Any account authenticating with a universal master password; LSASS tampering on a DC	T1556.001
DCShadow	4928/4929 (replication source added), 5137 (server/nTDSDSA object created)	A new "DC" object in the Configuration partition from a non-DC host	T1207
Krbtgt / trust key abuse	`krbtgt` password changes (4723/4724); cross-trust 4768/4769	Unexpected `krbtgt` resets, or tickets crossing a trust with extra SIDs (SID-filter gaps)	T1134.005, T1558
Zerologon / Netlogon	5827-5829 (Netlogon denied vulnerable connections), 4742 reset of the DC machine account	A DC computer account password reset from a non-DC source	T1210

Reconnaissance

Attack	Telemetry	Hunt signal	ATT&CK
LDAP/AD recon (SharpHound, ADExplorer, AD-based collectors)	LDAP query logs (event 1644 with diagnostic logging on); Defender for Identity	One host issuing thousands of LDAP queries, broad filters like `(objectClass=*)` / `(servicePrincipalName=*)`	T1087.002, T1069.002
SMB session / local-admin enumeration	4624 type 3 bursts; Zeek `smb_mapping` ; flow to many hosts on 445	One source touching many hosts' IPC$ in minutes	T1135, T1018
Trust and DC enumeration	4661/4662 on trust objects; process creation of `nltest` , `dsquery`	`nltest /domain_trusts` , bulk trust/DC lookups from one host	T1482, T1018

Turn the auditing on

Most of the above is invisible without Advanced Audit Policy and, for object reads/writes, a **SACL** on the object. Baseline for domain controllers:

- **Account Logon**: Kerberos Authentication Service, Kerberos Service Ticket Operations, Credential Validation (4768/4769/4776).
- **Logon/Logoff**: Logon, Special Logon (4624/4625/4672).
- **DS Access**: Directory Service Access (4662), Directory Service Changes (5136/5137/5138/5139/5141). Needs SACLs; set audit ACEs on the domain head, AdminSDHolder, GPO container, the AD CS PKI container, and sensitive attributes (`msDS-KeyCredentialLink` , `msDS-AllowedToActOnBehalfOfOtherIdentity` , `ms-Mcs-AdmPwd` / `msLAPS-*`).
- **Account Management**: User, Computer and Security Group Management (4720-4743, 4728-4733, 4741/4742/4781).
- **Detailed Tracking**: Process Creation with command line (4688; enable "Include command line" via GPO, Administrative Templates, System, Audit Process Creation).

- **Policy Change**: Audit Policy Change (4719), Authentication Policy Change (4713/4716/4739).
- **System**: Security System Extension (4697), Security State Change.
- Temporary deep hunts: **LDAP diagnostic logging** (`Field Engineering` = 5 under `NTDS\Diagnostics` gives 1644; also set the search-stats thresholds) and **Restrict NTLM auditing** for relay and pass-the-hash work.
- **AD CS**: on each CA enable auditing of "Issue and manage certificate requests" (4886/4887/4888/4889) and CA config/security changes (4890/4882); audit changes to certificate templates.

See Data and telemetry and the Windows event ID sheet for the full event detail.

Add context, cut noise

- **Attack-path mapping**: BloodHound/BloodHound CE, PingCastle, Purple Knight and `Locksmith` (AD CS) show the paths and misconfigurations before an attacker walks them, and tell you which hunts matter most.
- **Microsoft Defender for Identity**: sensor-based detections for many techniques here; treat its alerts as leads into the raw events, not as the whole picture.
- **Honeytokens**: a disabled admin with an SPN (any 4769 for it is a Kerberoast), a decoy service account, a canary share (any 5140/5145 is a hit), and a fake `msDS-KeyCredentialLink`-eligible object.
- **Protected Users, AES-only, gMSA/dMSA, tiered admin and LAPS** shrink the attack surface, so legitimate RC4, delegation and local-admin reuse become rare enough to alert on.

Detailed playbooks: AD discovery and BloodHound · Kerberoasting · DCSync · AD CS abuse · LSASS credential dumping · Lateral movement · RDP and WinRM anomalies

HUNT-SAGE
iamjammie/hunt-sage